

Threat Modeling of a Web Application Using Microsoft Threat Modeling Tool

1. Aim

To perform threat modeling of a web application using the Microsoft Threat Modeling Tool by creating a Data Flow Diagram (DFD), identifying trust boundaries and potential security threats using the STRIDE methodology, and generating a threat-modeling report with appropriate mitigations.

2. Procedure

Step 1 – Open Microsoft Threat Modeling Tool

- Launch Microsoft Threat Modeling Tool.
- Select Create a Model.
- Choose an appropriate template, such as the SDL TM Knowledge Base for a generic application.

Step 2 – Create the DFD

Create the following components:

Component	Type
User	External Entity
Web Application	Process
Backend API	Process
User Database	Data Store
File Storage	Data Store
Internet / Public Network	Trust Boundary / boundary representation
Secure Internal Data Layer	Trust Boundary

The flow is:

- User → Web Application → Backend API → User Database
- Backend API → File Storage
- User → Web Application → File Upload

Step 3 – Add data flows

Add and name the flows:

- Login Request
- File Upload
- API Request
- Database Read/Write

- Store Uploaded File

These names make it clear what data moves between the components.

Step 4 – Add trust boundaries

Identify where the level of trust changes. For this design, the important boundary is:

- Internet / Public Network → Internal Application/API

Another boundary represents the secure internal data layer around the database and file storage.

In Microsoft's approach, trust boundaries are represented by red dotted lines and indicate that different entities are under different levels of control.

Step 5 – Analyze the model

Go to Analyze / Analysis View. The tool automatically generates potential threats based on the DFD and the selected template. Microsoft uses the STRIDE methodology:

- S – Spoofing
- T – Tampering
- R – Repudiation
- I – Information Disclosure
- D – Denial of Service
- E – Elevation of Privilege

Step 6 – Review each threat

For every generated threat:

- Select the threat.
- Read its description.
- Check its STRIDE category.
- Set its priority.
- Add justification if necessary.
- Add or verify the mitigation.
- Change the status appropriately.

The tool supports statuses such as Not Started, Needs Investigation, Mitigated, and Not Applicable.

Step 7 – Apply mitigations

For example:

Threat	Possible Mitigation
Spoofing	Strong authentication, MFA
Tampering	HTTPS, input validation, integrity checks

Threat	Possible Mitigation
Repudiation	Audit logs
Information Disclosure	Encryption, access control
Denial of Service	Rate limiting, request validation
Elevation of Privilege	RBAC, least privilege

Step 8 – Generate the report

After reviewing the threats, go to Reports → Create Full Report → Save Report. Create Full Report is the documented way to generate the complete threat-model report.

3. Data Flow Diagram

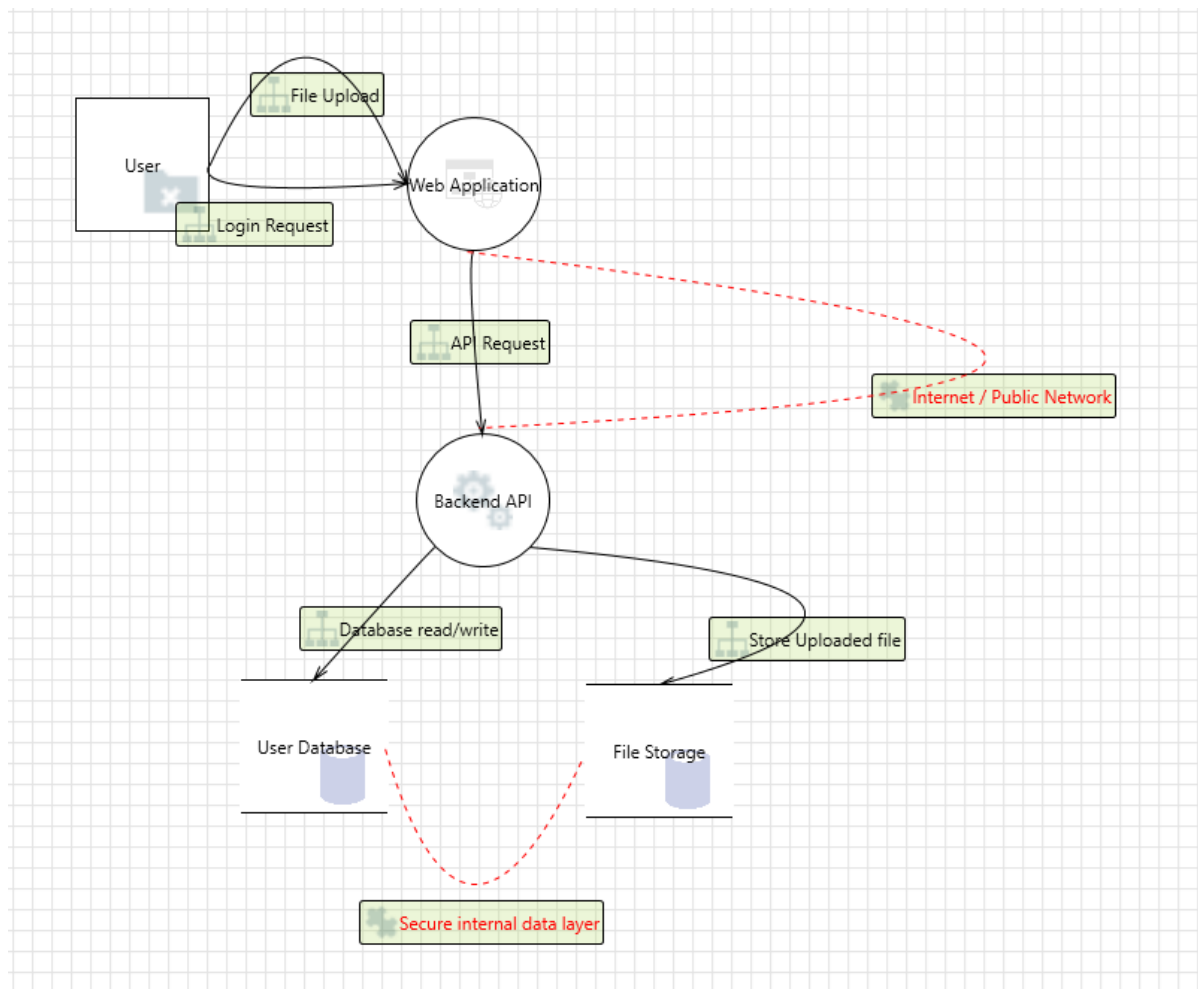


Figure: Data Flow Diagram of the Web Application